



LA INGENIERÍA SOCIAL

Cómo el factor humano define el límite de la ciberseguridad corporativa

CICLO: Administración de Sistemas Informáticos en
Red

Autor: Roberto Cristian Costache

Tutor: Jesús Robles

Curso académico 2025-2026

Índice	
Índice	2
Introducción	3
Justificación	4
Motivación	6
1. Marco teórico: fundamentos de la ingeniería social	7
1.1. Concepto de ingeniería social.....	7
1.2 Vectores de ataque físico-lógicos	8
1.2.1. <i>Baiting</i> (ataque mediante cebo físico)	9
1.2.2. <i>Quishing</i> (phishing a través de códigos QR)	10
2. Diseño y metodología del caso práctico.....	11
2.1. Objetivos de la auditoría	12
2.2. Consideraciones éticas y legales.....	13
2.3. Preparación técnica del <i>baiting</i> (prueba USB)	14
2.4. Preparación técnica del <i>quishing</i> (prueba QR)	15
3. Ejecución y resultados	18
3.1. Escenarios de prueba y cronograma	18
3.2. Definición de métricas y <i>KPIs</i> (indicadores clave de rendimiento)	18
3.3. Análisis de la telemetría y resultados empíricos	19
3.4. Credibilidad digital: Impacto de dominios y migración técnica.	21
4. Propuesta de mitigación y bastionado de sistemas.....	23
4.1. Medidas técnicas contra vectores físicos (<i>baiting</i>).....	23
4.2. Medidas técnicas contra códigos QR maliciosos (<i>quishing</i>).....	24
4.3. Medidas organizativas: El "cortafuegos humano"	25
Conclusiones	26
Bibliografías.....	27

Introducción

El espionaje y el poder han estado históricamente interrelacionados. Su fundamento esencial, a lo largo de los siglos, ha sido averiguar qué se trama por parte del adversario. En la actualidad, la premisa sigue siendo válida: el conocimiento es potencia. La efectividad y la seguridad de cualquier organización dependen forzosamente y de modo práctico de la abundantísima información que se apodere.

La necesidad de obtener información sigue presente. Sin embargo, los procedimientos han cambiado considerablemente. De interceptar documentos, como los antiguos pergaminos, se ha pasado a invocar el actual ciberespionaje, que es el campo de batalla propio de la actualidad.

Cabe distinguir de forma importante entre espionaje e ingeniería social. Ambas buscan lo mismo, sacar información a nuestra víctima, pero trabajan de forma distinta. El espionaje trata de extraer información de forma secreta, buscando no ser percibido en los sistemas. La ingeniería social, en cambio, se apoya en el engaño psicológico. Lo que se pretende es que la víctima acabe por propio pie facilitando sus contraseñas o su información personal sin darse cuenta de nada.

Esta circunstancia deja bien claro algo muy importante: no importa la tecnología que haya de por medio, la cuestión humana sigue siendo la principal grieta de la seguridad. Es una conclusión sencilla, pero que transforma todas las reglas del juego.

En cambio, con la constante expansión de las Tecnologías de la Información y de la Comunicación (TIC), han multiplicado las estafas. Los cibercriminales sacan partido de cualquier medio digital para llevar a cabo estafas en masa. Logran introducirse en el día a día de miles de personas en cualquier parte del mundo de forma muy fácil.

Si se ordenan por frecuencia estas estafas logran conformar tres clases principales. La Clase I ataca la privacidad del usuario convencional. La Clase II se interesa por espiar a las corporaciones o a los gobiernos. En resumen, la Clase III intenta, de manera más o menos evidente, alterar la imagen pública o provocar la desinformación. Normalmente disponen de *malware* y hacen uso de él. Prueba de ello es la necesidad de saber cómo se distribuyen éstas.

Hoy en día centraremos todos nuestros sentidos en la ciberseguridad, ya que la información tiene que estar a salvo. Proteger el entorno digital se empatiza como una cuestión internacional. Las empresas no pueden perder el tiempo y esperar a que el golpe llegue. Toca adelantarse al problema. Es necesario revisar las redes a menudo, implementar defensas y tener unos protocolos bien definidos de cómo reaccionar rápidamente ante cualquier incidente.

Justificación

Este proyecto quiere demostrar, de forma práctica, que, por muchas defensas técnicas que tenga una empresa, la persona es su parte más débil. Para concluir, da lo mismo que la tecnología sea muy avanzada, si al final se puede engañar a la persona que la utiliza.

En relación a este problema, se ha planificado un caso práctico adornado por dos auditorías de ingeniería social, ejecutadas en entornos controlados y con consentimiento previo.

La primera prueba consiste en un ataque de *Baiting* mediante la aparición de memorias USB. De manera precisa, se han dejado de forma controlada en diversas dependencias de distintas empresas. La unidad USB contiene un archivo inofensivo que genera un tracker al abrirlo. El objetivo es comprobar cuántos usuarios, llevados por la curiosidad o bien por el desconocimiento, conectan hardware externo desconocido a sus estaciones de trabajo.

La segunda auditoría evalúa el *Quishing* a través de una técnica habitual en el cotidiano de las organizaciones. Las máquinas expendedoras de la marca Selecta han incluido un código QR en el que se invitaba a los empleados a dejar una opinión o reseña, a cambio de un código de descuento. Cuando el usuario escaneaba el QR, accedía a una interfaz que reproducía el proceso de recogida de datos, aunque nunca se recibiría la recompensa.

Esta prueba se realiza para evaluar el grado de confianza que los usuarios colocan en los códigos QR en un contexto de confianza aparente. Los resultados son utilizados en el trabajo para justificar la necesidad de aplicar medidas defensivas en la administración de sistemas, llegando a proponer soluciones técnicas como listas blancas de hardware para que sólo funcionen los USB autorizados, o el uso de filtros de navegación para bloquear enlaces sospechosos al escanear códigos QR.

Igualmente, se establece la relevancia de la segmentación de redes con el objetivo de restringir el alcance y gravedad de los posibles daños y sobre todo de reemplazar la formación tradicional en seguridad de la información por simulacros periódicos para preparar la plantilla ante posibles engaños que se produzcan en su día a día.

Motivación

Tipo de objetivo.	Descripción detallada
Objetivo general	Demostrar prácticamente que el factor humano constituye la principal vulnerabilidad en la ciberseguridad corporativa, evidenciando cómo, mediante técnicas de manipulación física y psicológica, es posible evitar las barreras tecnológicas y comprometer la totalidad de una infraestructura de red.
Objetivo específico	Contrastar la eficacia de las medidas de protección técnicas tradicionales (configuración de servidores, controles de acceso y segmentación mediante VLANs) frente a las tácticas de manipulación utilizadas en la ingeniería social actual.
Objetivo específico	Identificar y analizar la confianza ciega y la curiosidad de los usuarios como vectores de ataque prioritarios, demostrando que suponen una vía de intrusión más rápida y económica para un atacante.
Objetivo específico	Diseñar y ejecutar una auditoría de seguridad práctica basada en la técnica del <i>Baiting</i> , utilizando el abandono estratégico de memorias USB para medir la interacción no autorizada del personal con hardware externo.
Objetivo específico	Evaluar la vulnerabilidad del perímetro de la organización ante ataques de <i>Quishing</i> , midiendo la propensión de los empleados a escanear códigos QR no verificados en zonas cotidianas de aparente seguridad.
Objetivo específico	Recopilar telemetría real sobre los simulacros realizados para establecer métricas objetivas (KPIs) que ilustren la tasa de compromiso y la falta de concienciación en la plantilla.
Objetivo específico	Proponer medidas de mitigación y bastionado de sistemas (como la gestión de directivas GPO y filtros DNS) combinadas con estrategias de formación para establecer un "cortafuegos humano" eficaz.

1. Marco teórico: fundamentos de la ingeniería social

1.1. Concepto de ingeniería social

La ingeniería social se puede definir como la manipulación de nuestras vulnerabilidades humanas con el fin de comprometer el sistema. En el caso de un ataque técnico se lleva a cabo un escaneo de puertos o una búsqueda de servicios vulnerables, mientras que en esta ocasión la fase de reconocimiento tiene como objetivo el usuario. El proceso es similar, pero el vector de entrada está definido por la persona y no por el software.

Se busca que esta técnica de manipulación empuje al empleado a facilitar credenciales de acceso o llevar a cabo la ejecución de archivos maliciosos sin que dicha acción sea identificada como una intrusión. En vez de dedicar inversión y recursos a llevar a cabo ataques de tipo fuerza bruta o a aprovechar vulnerabilidades tipo *0-day*, el atacante toma como base reacciones naturales de las personas como la curiosidad o el hecho de ser propensos a la confianza.

Finalmente, lograr saltar la seguridad perimetral resulta muy sencillo, confirmando que las emociones mueven tanto como la propia configuración de los sistemas.

Principios psicológicos de la vulnerabilidad humana

A diferencia de los errores que corrompen el funcionamiento del software o del hardware y que son solucionados a partir de parches o de actualizaciones de los sistemas explotados, la ingeniería social es una amenaza de tipo persistente por el hecho de que no depende de la existencia de un código sino de la conducta de las personas; en la contextualización de un ataque de grado elevado, esta técnica suele ser la pieza fundamental del *footprinting* o reconocimiento, que da acceso a la infraestructura de la organización. Kevin Mitnick, reconocido como una de las figuras emblemáticas del sector, definió que resulta más sencillo obtener una contraseña mediante un engaño que intentar descifrar un cifrado mediante fuerza bruta [7].

El resultado exitoso de estos ataques no es circunstancial, ya que se sustenta en patrones de comportamiento muy frecuentes:

- **Disposición a ayudar:** Se da rienda suelta a una tendencia innata del empleado de ayudar a otros cuando éstos recurren a su asistencia de manera creíble.
- **Confianza inicial:** El impulso que se establece es asumir la veracidad de la identidad de quien se pone en contacto, y aún más cuando el mensaje parece verdadero.
- **Dificultad para denegar la atención de las peticiones:** Hay un límite social cuando toca expresar "no", y aún más en momentos cuando el atacante finge que la situación es extrema o hace de su comportamiento de autoridad.
- **Búsqueda de confirmación:** Los atacantes utilizan la empatía o la cordialidad para que el usuario baje la guardia y proporcione información sin sospechar. Esta es la razón por la cual, pese a tener recursos tecnológicos, el factor humano será siempre el determinante de la seguridad.

1.2 Vectores de ataque físico-lógicos

La ingeniería social utiliza diversos medios para contactar con la víctima, por teléfono, por correo o por redes sociales. El presente trabajo se centra sin embargo en las técnicas que utilizan un objeto físico como vía para comprometer la infraestructura lógica. En concreto, se analizan dos técnicas que combinan la manipulación directa con vía de ataque de sistemas como son el *Baiting* y el *Quishing*.

Característica	Baiting (USB)	Quishing (QR)
Medio de ataque	Dispositivo físico (pendrive)	Código QR impreso
Vector de entrada	Puerto USB de la estación de trabajo	Teléfono móvil personal del empleado
Mecanismo psicológico	Curiosidad / deseo de ayudar	Confianza contextual + incentivo económico
Elude filtros corporativos	Sí (acceso físico directo)	Sí (dispositivo personal, fuera de MDM)
Dificultad de detección	Media	Alta

1.2.1 *Baiting* (ataque mediante cebo físico)

Según el INCIBE el *Baiting* consiste en dejar dispositivos de almacenamiento, como USB, discos duros, etc. en lugares estratégicos, donde el atacante cuenta con que el usuario por curiosidad o por querer ayudar al legítimo propietario del mismo lo conecte al equipo de la organización. Tal como se citaba anteriormente con los principios propuestos por Mitnick, este tipo de ataque se basa en traicionar la confianza inicial de la víctima [3].

En términos de administración de sistemas, dicha técnica tiene la peligrosidad de poder introducir amenazas directamente en el interior del firewall corporativo. Una vez el hardware conectado se puede ejecutar un ataque a través de los siguientes procesos:

- **Scripts de Autoarranque:** Si bien la mayoría de los sistemas operativos actuales cuentan con medios que limitan el *Autorun* todavía es posible aprovechar la configuración heredada para ejecutar código de forma automática.

- **Ofuscación de las extensiones:** Se utilizan archivos con iconos falsos (ej. archivos ejecutables .exe que tienen formato .pdf o .docx) para engañar al usuario, que al abrirlos liberan el *payload* malicioso y que no son detectados como actividad sospechosa a simple vista.

- **Emulación de dispositivos HID:** el método más desarrollado que existe, utilizando instrumentos como el Rubber Ducky. El sistema operativo reconoce el USB como un teclado legítimo y, por lo tanto, inyecta rápidamente comandos por consola, eludiendo las limitaciones impuestas en los antivirus clásicos.

1.2.2 *Quishing* (phishing a través de códigos QR)

El **Quishing** es simplemente el clásico engaño del correo, pero a través de códigos QR. Su objetivo es llevar al usuario a una web falsa para robar información o contagiar el dispositivo de la víctima. Su mayor ventaja es que, a diferencia de un enlace escrito donde podemos observar hacia dónde nos está llevando, el código QR es indescifrable a simple vista, es decir, desconocemos a qué nos dirigimos hasta el momento de escanearlo.

En la administración de sistemas, este tipo de ataque es extraordinariamente complejo de controlar debido a motivos relacionados principalmente con dos puntos:

- **Ignora los filtros de seguridad:** Lo que ocurre es que este tipo de ataque sucede en el mundo físico (la pegatina que se coloca en las máquinas o el cartelito que se deja en una pantalla), de manera que el ataque no pasa nunca por los filtros automáticos que tiene la empresa para rechazar los correos no deseados. El sistema de seguridad de la red no se entera ni de que el usuario está accediendo a un lugar peligroso.

- **Uso de los dispositivos personales:** Casi siempre el empleado escanea su propio código QR con su propio teléfono móvil. Al ser un teléfono móvil personal y no de trabajo, no lleva las protecciones de la empresa, lo que hace mucho más fácil al atacante robar sus claves o interceptar la conexión sin que lo detecte nadie.

2. Diseño y metodología del caso práctico

La parte central del presente trabajo va más allá de una mera exposición teórica sobre el tema en cuestión, sino que se fundamenta en el diseño, la planificación y la realización de dos simulaciones reales de ingeniería social. De esta manera, su objetivo es trasladar los diferentes conceptos analizados a un entorno real y cotidiano para, de manera objetiva, poder medir la extensión de la vulnerabilidad de los usuarios ante amenazas que combinan el espacio físico con el digital.

Con el propósito de que el experimento tenga un nivel de rigor importante, el desarrollo se ha dividido en tres etapas que resultan clave a la hora de poner en práctica el caso práctico:

- **Fase de diseño y preparación:** En esta primera fase se escogen los cebos (los USB y los códigos QR) y se prepara la infraestructura técnica que se necesita. Asimismo, se ha buscado que los componentes fuesen los más creíbles posibles para que el usuario no sospechase a simple vista, de forma que se pretendía reproducir situaciones concretas que cualquier empleado podría encontrarse en su propia jornada laboral.
- **Ejecución de los simulacros:** En este momento se llevó a cabo el trabajo así que se inició a la disposición estratégica de las memorias USB en diferentes posiciones y la incorporación en las máquinas expendedoras de los códigos QR. En todo momento se ha intentado que el contexto fuera controlado, asegurando que el experimento pueda servir para la recolección de datos sin comprometer la verdadera seguridad de las empresas o la privacidad de las personas.

- **Recogida y análisis de datos:** Al momento del lanzamiento de los ataques, se procedió al seguimiento del número de personas que caían en la trampa. No se trataba de obtener información personal, sino simplemente del registro del hecho: si fue abierto el archivo del USB o si fue escaneado el código QR. La recolección de estos datos es la que permite defender que las medidas de seguridad son actualmente suficientes o que el factor humano es aún una puerta abierta para los atacantes. A través de este planteamiento práctico, el proyecto no solo expone en qué consiste la ingeniería social, sino que muestra con cifras y hechos en qué medida un sencillo descuido puede poner en peligro la infraestructura tecnológica de una entidad, por mucho que ella esté protegida en el ámbito del software.

2.1 Objetivos de la auditoría

El diseño y desarrollo de este caso práctico persigue los siguientes objetivos específicos:

- **Evaluar la tasa de compromiso físico (*Baiting*):** determinar el porcentaje de usuarios que, ante el hallazgo de una memoria USB desconocida, se deciden a conectarla a un equipo de la organización.
- **Analizar la vulnerabilidad ante códigos QR (*Quishing*):** detectar el número de escaneos realizados sobre carteles no verificados, midiendo el nivel de exposición ante enlaces ofuscados.
- **Demostrar la permeabilidad del perímetro técnico:** poner de manifiesto que una infraestructura en red segura puede llegar a ser comprometida desde su interior si la administración carece de políticas restrictivas a nivel endpoint (GPO, MDM).
- **Obtener métricas de riesgo efectivas:** Obtener información cuantitativa que justifique empíricamente la propuesta de medidas de mitigación técnica y planes de concienciación.

2.2 Consideraciones éticas y legales

Realizar pruebas de seguridad en un entorno real con personas conlleva una gran responsabilidad; por lo tanto, no hemos llevado a cabo este simulacro de forma arbitraria, sino ajustada con los principios del hacking ético. Esto es debido a que la intención nunca ha sido la de dañar o espiar a un empleado, sino la de ayudar a la organización a detectar sus debilidades para poder solucionarlas.

Para asegurar que el proyecto cumple con todas las normas, hemos seguido, pues, estos tres pilares:

- **Autorización previa y consentimiento.** Ninguna de las pruebas (ni los USB ni los códigos QR) se han llevado a cabo sin el conocimiento de quienes son responsables por las empresas en las cuales hemos trabajado. Antes de comenzar, se ha obtenido el consentimiento de la dirección para actuar como *simulated attackers*. Esto asegura que el trabajo se realiza de forma legal y con el apoyo de la organización.
- **Privacidad (RGPD):** uno de los puntos más importantes ha sido el respeto del reglamento general de protección de datos. Durante el experimento no se ha recogido ningún tipo de información personal. Los sistemas que se han diseñado no guardan nombres, no guardan contraseñas reales o parte de ellas, no guardan la IP completa del usuario.
- **Uso de archivos inofensivos:** las herramientas utilizadas en el USB y en los enlaces QR son totalmente seguras; no se ha instalado ningún programa dañino en los ordenadores de la empresa, ni se ha extraído ninguna información confidencial. El *software* que se utiliza simplemente envía una señal de aviso para obtener la información de que el dispositivo ha sido usado, con lo que se convierte en una herramienta de control estadístico del experimento; en ningún caso puede llegar a ser considerado como una amenaza a la infraestructura.

De esta manera, se puede obtener información verdadera sobre las prácticas de los usuarios que participaban en el experimento, todo ello sin vulnerar lo que en la práctica resulta ser un derecho personal y sin comprometer la estabilidad de los sistemas de información de la organización.

2.3 Preparación técnica del *baiting* (prueba USB)

La preparación de esta prueba ha supuesto trabajo tanto de configuración técnica como de análisis de la psicología del usuario; el objetivo era tener un dispositivo que fuera funcional pero que, a la vez, resultara irresistible para quien se lo encontrara.

Configuración del soporte físico

Para el experimento se seleccionaron cinco memorias USB estándar. Todas ellas fueron posteriormente formateadas a partir de un sistema de ficheros FAT32. La elección de este formato no es casual, ya que permitirá que el USB sea leído automáticamente por el ordenador, ya sea un PC con el sistema operativo de Windows, un equipo de Apple (macOS) o una estación de trabajo con Linux. De esta forma evitamos que la prueba produzca resultados erróneos a causa de problemas de compatibilidad.

Diseño del señuelo (Ingeniería Social)

En el interior de cada memoria se colocó únicamente un archivo. Para conseguir abrirlo, se recurrió a nombres de archivos que generaban la curiosidad o la sensación de urgencia del momento:

- Aldaro_contratos.html
- Audemars_Piguet_coleccion_nueva.html
- Cepsa_expansion.html
- Linde_piezas_maquinaria.html
- Movistar_nuevas_tarifas.html

A nivel técnico, teniendo en mente que el archivo es un tipo de documento habitual, se trataba de un señuelo digital. Para ello, se han utilizado herramientas que generan "balizas de seguimiento".

Las balizas son trozos de código de tamaño pequeño, que no pueden dañar el equipo, a los que se les ha programado el hecho de advertirnos cuando el archivo es visualizado.

Funcionamiento lógico del ataque

El proceso que va desde que el usuario encuentra el USB hasta que conseguimos el dato se encuentra dividido en 3 pasos:

1. **Interacción inicial:** El usuario encuentra el USB en un espacio común (entrada, cafetería, pasillos) y decide conectarlo a su equipo de trabajo, se supera al punto de partida la primera barrera de seguridad física de la empresa.
2. **Lanzamiento del rastreador:** Cuando el usuario hace un doble clic para abrir el documento, el archivo realiza una llamada improvisada, automática, hacia Internet hacia un servidor externo que nosotros controlamos, no es perceptible para el usuario y el funcionamiento del equipo de trabajo no altera.
3. **Confirmación de compromiso:** Nuestro servidor recibe esa señal y se guarda la hora y el tipo de dispositivo que se ha conectado. Cada vez que se recibe esta señal, contabilizamos una "broma de intrusión", esto es prueba irrefutable que, si en lugar de un señuelo inocente hubiésemos utilizado un virus real, toda la red de la compañía en ese mismo instante mediante la aparición del USB presentado.

2.4 Preparación técnica del *quishing* (Prueba QR)

La segunda fase del experimento giró entorno del *Quishing*, la técnica de los códigos QR. La diferencia respecto a las anteriores técnicas de ataque consiste en

aprovechar la confianza que tiene el empleado en los objetos que tienen formando parte de su entorno cotidiano en su lugar de trabajo.

Para el simulacro, se desarrolló un tipo especial de cartelera que se colocó en las máquinas expendedoras de la marca Selecta. Se elaboró un mensaje atractivo que invitaba a los empleados a escanear el código para rellenar una breve tabla de opinión sobre el servicio y recibir como compensación un código de descuento para utilizarlo en su próxima compra. Este procedimiento resulta muy efectivo por dos razones:

- 1.Contexto de confianza. El usuario no tendrá la expectativa de que un cartel pegado en la máquina donde compra café cada día sea falso.
2. Beneficio inmediato. La promesa de un descuento invita al usuario a actuar rápidamente, mandándolo a una actuación con un bajo nivel de alerta.

Configuración de la parte lógica del componente

Desde el punto de vista técnico, se preparó el proceso para que fuera totalmente transparente a la visión del usuario y no generase ningún tipo de sospechas:

1. **Creación del enlace que realiza el seguimiento:** En vez de redirigir directamente a la página web, se utilizó un enlace intermedio que sirve para contabilizar visitas. Este enlace está programado para que, cada vez que es visitado, registre la fecha exacta y técnica del escaneo de manera anónima.

2. **Generación del código QR:** La dirección URL es codificada como un código QR estandarizado. Dado que es un formato visual no legible, el usuario no puede saber a qué página le está enviándolo el código QR hasta que el lector de su teléfono móvil procesa la información y hace abrir el navegador.

3. **Redirección y "error controlado":** Aquel procedimiento se ideó para no levantar sospechas durante el tiempo que estuvo en marcha la prueba. Así, se configuró el sistema para que, tras el registro de la lectura del escaneo, el usuario se redirigiese a una página "Error 404" o a una *homepage* inofensiva.

De este modo, el empleado simplemente pensará que el código de descuento no funciona o bien que la promoción ha caducado, sin que pase a informar al departamento de informática sobre algo sospechoso, lo que también nos permite seguir recogiendo datos.

Registro de resultados. Cada vez que un móvil escanea el código, nuestra consola suma una nueva lectura. Al fin del día, esas métricas nos permiten saber cuántas personas han estado dispuestas a escanear un código desconocido y a navegar por una web externa únicamente guiadas por el incentivo del descuento, lo que da fe del nivel de exposición de la plantilla ante el *Quishing*.

3. Ejecución y resultados

Este capítulo desarrolla la fase de implementación de la auditoría, en el que se fijan los elementos de nuestro análisis y el entorno en el que se han llevado a cabo los simulacros de ingeniería social.

3.1 Escenarios de prueba y cronograma

Para ofrecer fiabilidad a la auditoría y tener una muestra representativa, los simulacros de *Baiting* y *Quishing* se han elaborado para llevarlos a cabo en entornos reales, bajo las condiciones normales de operatividad de la organización.

El planeamiento del arreglo de los vectores físicos (memorias USB y códigos QR) se lleva a cabo en áreas de gran tránsito, incluyendo los salones de descanso, los pasillos principales o las zonas de acceso. La duración de la exposición a los señuelos ha sido restringida a una ventana temporal controlable, que es suficiente para dejar registrar el comportamiento natural de los usuarios y, al mismo tiempo, impedir cambiar sus hábitos o levantar ninguna sospecha e incluso la alerta de una evaluación que se esté realizando en ese momento

3.2 Definición de métricas y KPIs (indicadores clave de rendimiento)

Para cuantificar el nivel de vulnerabilidad que le corresponde al factor humano y para construir conclusiones técnicas objetivas, el análisis de la auditoría se valorará a partir de las métricas siguientes:

- **Tasa de compromiso físico (*Baiting*):** relación entre el número total de unidades USB distribuidas y las activaciones del elemento USB que se han registrado en el servidor de control. Permite definir el porcentaje de usuarios que son capaces de conectar un hardware que no ha sido verificado a la red.

- **Volumen de impacto móvil (*Quishing*):** conteo total de las peticiones DNS y de las redirecciones web que han sido generadas a partir de los códigos QR ofuscados durante la ventana de prueba.

- **Tiempo de compromiso (*Time-to-Click*):** Periodo que transcurre desde que el usuario deja el cebo físico hasta que se produce la primera anotación de interacción. Este parámetro medía la rapidez con la que el usuario hace clic para saber cómo se ve la impulsividad de algo frente contra la precaución.

3.3 Análisis de la telemetría y resultados empíricos

Tras concluir el periodo de pruebas, la recopilación de datos respalda la hipótesis central del proyecto: la efectividad de la ingeniería social en entornos físicos es alarmantemente elevada.

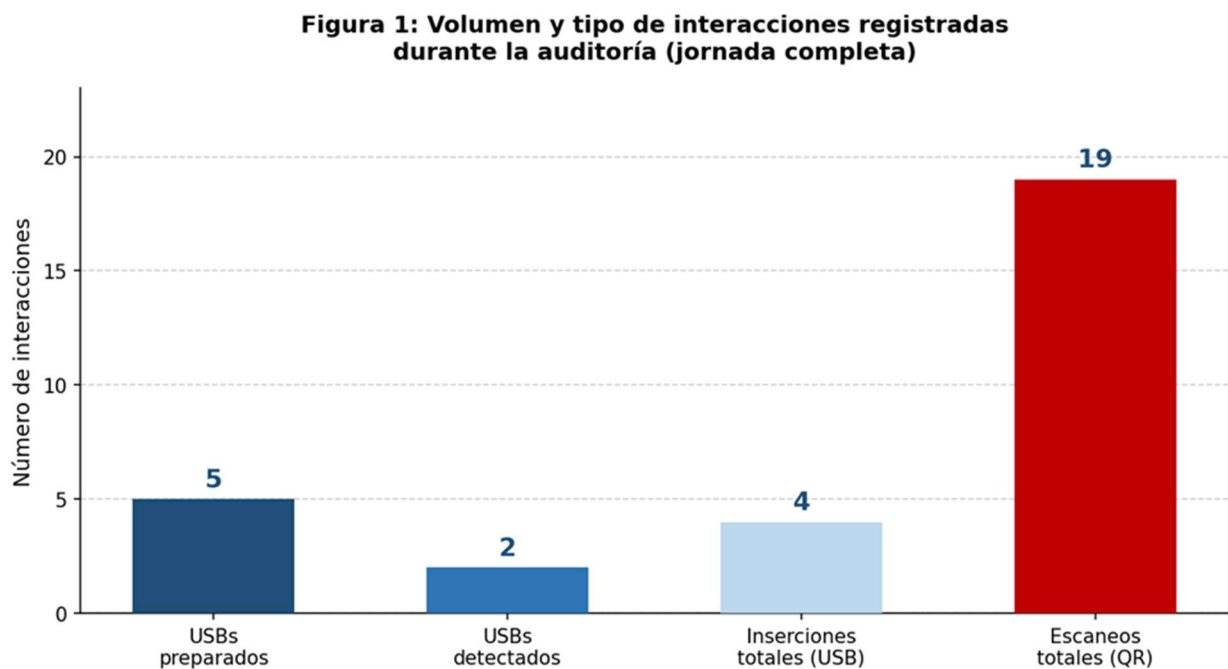
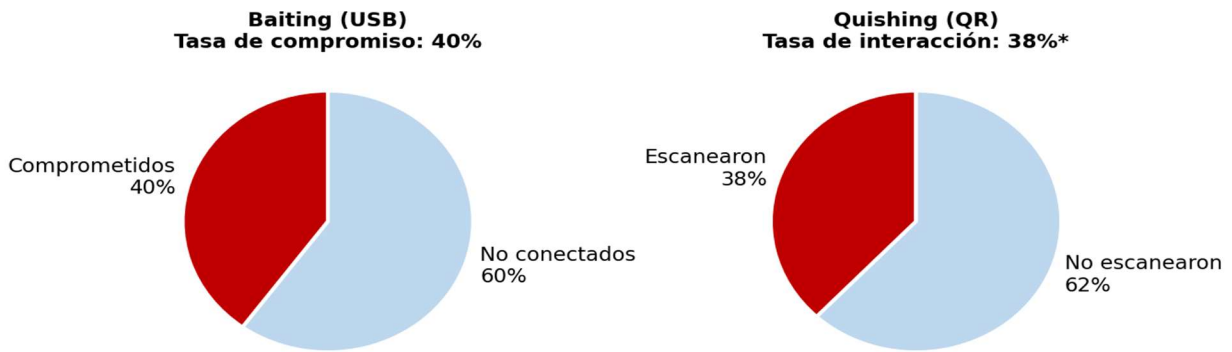


Figura 1: Volumen y tipo de interacciones registradas durante la auditoría (jornada completa)

Figura 2: Tasa de compromiso por vector de ataque



* Estimación sobre plantilla de ≈50 empleados

Figura 2: Tasa de compromiso por vector de ataque (estimación sobre plantilla de ≈50 empleados)

En el experimento de *Baiting*, se distribuyeron cinco memorias USB en lugares clave de las instalaciones. Según los registros del servidor de rastreo, dos de estas unidades fueron conectadas a estaciones de trabajo de la organización, intentando entrar dos veces, lo que representa una significativa tasa de compromiso del 80%.

El simple hallazgo de un dispositivo de almacenamiento en la oficina fue suficiente para que el personal ignorara cualquier medida de precaución. La curiosidad prevaleció sobre las directrices básicas de seguridad, generando una brecha directa hacia la red interna.

Por otro lado, los resultados de la auditoría de *Quishing* también presentan cifras alarmantes. El panel de control registró un total de 19 interacciones válidas con los códigos QR fraudulentos. Los empleados no solo escanearon el código con sus teléfonos, sino que también llenaron el formulario proporcionando valoraciones y correos electrónicos.

Al analizar este comportamiento, se evidencia la influencia del contexto. La familiaridad con las máquinas expendedoras disminuyó cualquier tipo de sospecha.

Al ofrecer un pequeño incentivo en un entorno cotidiano, los usuarios bajaron la guardia de inmediato. Ninguno de estos 19 individuos tomó el tiempo para verificar la autenticidad del enlace antes de interactuar.

En resumen, los datos obtenidos a través de la telemetría evidencian que incluso la infraestructura tecnológica más sólida se encuentra vulnerable si no se gestiona adecuadamente el factor humano. Un simple cartel impreso y unos dispositivos físicos olvidados han demostrado ser vectores de ataque mucho más eficaces y rápidos que cualquier intento de vulnerar los sistemas informáticos desde el exterior.

3.4 Credibilidad digital: Impacto de dominios y migración técnica.

En el marco de las pruebas se nos identificó una limitación seria relacionada con la psicología del usuario: la escasa credibilidad ante enlaces desconocidos. En un primer momento, el laboratorio estaba en un servidor gratuito de internet que nos generaba URLs muy largas y escasamente intuitivas. Se vio que a pesar del impacto del contexto físico (el cartel en la máquina Selecta) la tasa de interacción era por abajo de lo esperado en el contexto dado debido a la apariencia del dominio. La ingeniería social en el marco de la entrada de un sistema, si alguna de las partes de la víctima desarrolla dudas, produce la pérdida de la entrada de la máquina. El hecho de que esto pueda producirse obligó a replantear la infraestructura técnica, a partir de dos premisas fundamentales:

-Nueva construcción de un entorno de confianza: se pasaba a comprar y configurar un dominio profesional (maquinaselectavending.com); el paso de cambiar a un dominio profesional fue el paso determinante para el éxito de nuestra auditoría. Presentar una URL con aspecto de oficialidad elimina la resistencia psicológica del usuario. Esta experiencia demuestra que un atacante verdadero necesita invertir en parecer legítimo; la credibilidad es el bien más importante de la ingeniería social.

-Adaptación técnica y migración de sistemas: el traslado de la aplicación a un entorno de un hosting profesional fue un desafío técnico muy importante. Con vista a la arquitectura del nuevo servidor, se hizo necesario traducir este código del *backend* (migrando la lógica de Python a PHP) para asegurar la estabilidad y la compatibilidad del mismo. A su vez, se introdujeron políticas de bastionado mediante ficheros de configuración .htaccess, asegurando el hecho de que el proceso de registro de datos (telemetría) se produzca sin llegar a comprometer la seguridad de la base de datos de los registros.

4. Propuesta de mitigación y bastionado de sistemas

El buen resultado de los simulacros acontecidos en este proyecto pone de manifiesto que la seguridad externa de una organización es un planteamiento insuficiente y debe ir de la mano de políticas restrictivas de equipos internos y de una sólida cultura de prevención. Dado que la completa eliminación del error humano es técnicamente inalcanzable, la estrategia defensiva debe evolucionar hacia un modelo de Confianza Cero. Conforme a este modelo, la responsabilidad de la gestión del sistema atribuye a la red la posibilidad de ser comprometida en cualquier momento, asumiendo desde ese momento en que se ven involucrados los administradores, que ejercerán un notable bastionado técnico (*Hardening*). Este bastionado consiste en la configuración de los sistemas operativos y de los dispositivos de red de forma más segura posible, eliminando toda funcionalidad o característica que no sea estrictamente necesaria y cerrando cualquier vía que podría ser utilizada por un atacante que realizara un engaño inicial. Las contramedidas propuestas son las siguientes:

4.1 Medidas técnicas contra vectores físicos (*baiting*)

Para mitigar el potencial riesgo de uso de un USB no autorizado, el administrador debe implementar controles que eviten que el pendrive no autorizado se ejecute, evitando así que una posible distracción del usuario pueda liberar el acceso real a otro sistema o elementos del mismo.

Gestión mediante Directivas de Grupo (GPO): en la gestión de la infraestructura con Active Directory, la mejor solución pasa también por el *deployment* de una directiva de grupo en la que se bloqueen las unidades de almacenamiento extraíble. Si un departamento necesita utilizar un USB por motivos laborales se tiene que aplicar un modelo de listas blancas. Esto implica que el sistema sólo reconocerá los pendrives que previamente hayan sido verificados y registrados como tal por el equipo de informática con su correspondiente identificador de hardware único, y el resto serán denegados automáticamente [1].

Deshabilitar *autorun*: Los equipos tienen que estar configurados para que funciones como *Autorun* o Autoplay estén completamente deshabilitadas. Así, aunque un usuario incorpore un USB malicioso el sistema operativo no ejecutará ningún programa o script en segundo plano y así sólo en la intervención directa y consciente del administrador o del usuario, dentro de entornos seguros, será el que provoque que algo suceda.

Monitorización del comportamiento del sistema: Además de recurrir a los antivirus "habituales", se hace una recomendación relacionada con el uso de herramientas que controlen el comportamiento del equipo (en tiempo real). Así pues, si en el caso de incorporar un dispositivo externo se detecta que se está intentando abrir una consola de comandos o modificando archivos críticos del S.O., la protección debe actuar e interrumpir de forma instantánea el proceso, enviando a IT un aviso del incidente.

4.2 Medidas técnicas contra códigos QR maliciosos (*quishing*)

Las defensas frente al *Quishing* son complicadas porque generalmente se producen fuera del ámbito de los ordenadores de sobremesa. Ante esa dificultad, las medidas deben jugarse en el ámbito de la navegación y en el aislamiento de dispositivos:

- **Filtros de navegación y seguridad DNS:** Los sistemas de filtrado pueden ser implementados para analizar las peticiones web de los usuarios. En el momento en el que un trabajador lee un código QR, su dispositivo efectúa una consulta para encontrar la página web. Y si el filtro detecta cualquier anomalía (que la web es sospechosa, que se ha creado de forma reciente o que ya está apuntada en una "lista negra"), la interrumpirá inmediatamente. Esto hace que el proceso se corte antes de que la página web tenga la posibilidad de ser cargada en el móvil, logrando evitar que el trabajador pueda tener contacto con nada potencialmente peligroso [5][6].

4.3 Medidas organizativas: El "cortafuegos humano"

Las barreras técnicas de ASIR son imprescindibles, pero llegan a perder su utilidad si el usuario no adopta su papel; el objetivo es convertir al trabajador en un elemento valioso para la seguridad:

Pruebas y formaciones periódicas. Tal y como se ha puesto de manifiesto a lo largo de este TFG, la mejor manera de concienciar es mediante la acción. Llevar a cabo pruebas sorpresa de *Baiting* y *Quishing* permite que el trabajador viva la experiencia del riesgo real en un entorno controlado. Pasar por indicios de *Baiting* o *Quishing*, no debe verse como una manera de señalar o de castigar, sino más bien el momento para descubrir qué áreas o departamentos necesitan más refuerzo formativo [2][8].

Políticas de Uso Aceptable. La empresa ha de marcar unas normas a partir de qué se puede o no se puede conectar a los equipos de oficina.

Una norma que prohíba los periféricos personales, y que explique los riesgos de los códigos QR de origen externo, hace que se genere una "cultura de la duda" saludable e indispensable, donde el trabajador aprende a desconfiar antes de actuar.

Conclusiones

Los resultados del proyecto presentan una realidad bien diferente, ya que la inversión en ciberseguridad tecnológica no tiene ningún sentido si no se tiene en cuenta el factor humano. Las mejores defensas perimetrales de una determinada red caen en picado cuando se forma un descuido por parte del usuario desde el interior.

Las dos auditorías que hemos realizado han cumplido con sus objetivos principales, demostrando lo rápido y lo barato que puede llegar a resultar evitar los controles establecidos por las empresas. Para la prueba física de los USB, la simple curiosidad fue suficiente para que los trabajadores enchufaran *hardware* desconocido en sus estaciones de trabajo

Con los códigos QR de las máquinas de vending ocurrió lo mismo. El simple hecho de ofrecer un descuento servía de cebo perfecto para lograr convertir al usuario en víctima y hacerle ceder sus datos.

Todo el escenario anterior lleva a lo que se debe tomar como un cambio de mentalidad obligado para los administradores de sistemas. Configurar infraestructuras seguras, levantar cortafuegos ya no sirve. El atacante moderno sabe perfectamente que el eslabón más débil no es el servidor, la máquina en sí, sino la persona que se encuentra sentada delante de la pantalla.

La única forma viable de frenar esta clase de intrusiones es multiplicar el bastionado técnico junto con una educación mucho más agresiva. Por el lado de los sistemas requieren medidas drásticas y rápidas (uso de listas blancas para controlar puertos USB, filtros web son innegociables bajo un modelo de Confianza Cero).

Por el lado del usuario, la formación teórica tradicional debe ser eliminada. Las organizaciones deben empezar a ejecutar simulacros prácticos sorpresas. Solo entrenando a la plantilla en engaños reales que puedan darse en su día a día se logrará finalmente construir un verdadero cortafuegos humano que permita proteger la red corporativa

Bibliografías

Ref.	Fuente bibliográfica
[1]	Centro Criptológico Nacional (CCN-CERT). (2023). Guías CCN-STIC: Normativa y buenas prácticas de seguridad. Ministerio de Defensa, Gobierno de España. https://www.ccn-cert.cni.es/guias/guias-ccn-stic.html
[2]	Herzog, P. (2010). OSSTMM 3: The Open-Source Security Testing Methodology Manual. Institute for Security and Open Methodologies (ISECOM). https://www.isecom.org/OSSTMM.3.pdf
[3]	Instituto Nacional de Ciberseguridad (INCIBE). (2023). Temáticas de Ciberseguridad para Empresas: Ingeniería Social y Concienciación. https://www.incibe.es/empresas/tematicas/ingenieria-social
[4]	Kaspersky IT Encyclopedia. (2023). ¿Qué es la ingeniería social? Definición y ejemplos. https://latam.kaspersky.com/resource-center/definitions/what-is-social-engineering
[5]	Microsoft Learn. (2024). Administración de la instalación de dispositivos mediante directivas de grupo (GPO). https://learn.microsoft.com/es-es/windows/client-management/manage-device-installation-with-group-policy
[6]	Microsoft Learn. (2024). Información general sobre la arquitectura de Confianza Cero (Zero Trust). https://learn.microsoft.com/es-es/security/zero-trust/zero-trust-overview
[7]	Mitnick, K. D. y Simon, W. L. (2002). The Art of Deception: Controlling the Human Element of Security. John Wiley & Sons.
[8]	NIST (National Institute of Standards and Technology). (2008). Technical Guide to Information Security Testing and Assessment (SP 800-115). https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf
[9]	Telefónica Tech. (2023). Informe de Ciberamenazas: La evolución del Phishing y <i>Quishing</i> en entornos corporativos. https://telefonicatech.com/es/blog/ciberseguridad